



CHRIST
(DEEMED TO BE UNIVERSITY)
BANGALORE • INDIA

A Project Report on
Compliance Automation Framework

Submitted in partial fulfillment of the requirements for the degree of

BACHELOR OF TECHNOLOGY

in

Computer Science and Engineering

by

T. Vijay Kumar 1860416

Under the Guidance of

Dr. Natarajan K

and

Mr. Deepak P

Department of Computer Science and Engineering,

School of Engineering and Technology,

CHRIST (Deemed to be University),

Kumbalgotu, Bangalore - 560 074

May-2022



CHRIST
(DEEMED TO BE UNIVERSITY)
BANGALORE • INDIA

School of Engineering and Technology
Department of Computer Science and Engineering

CERTIFICATE

This is to certify that **T. Vijay Kumar** has successfully completed the project work entitled “**Compliance Automation Framework**” in partial fulfillment for the award of **Bachelor of Technology in Computer Science and Engineering** during the year **2021-2022**.

Dr. Natarajan K
Associate Professor

Mr. Deepak P
Senior Engineer, Tata Elxsi

Dr. K Balachandran
Head of The Department

Dr. Iven Jose
Dean



CHRIST
(DEEMED TO BE UNIVERSITY)
BANGALORE • INDIA

School of Engineering and Technology
Department of Computer Science and Engineering

BONAFIDE CERTIFICATE

It is to certify that this project titled "Compliance Automation Framework" is the bonafide work of

Name	Register Number
T. Vijay Kumar	1860416

Examiners [Name and Signature]

- 1.
- 2.

Name of the Candidate :

Register Number :

Date of Examination :



January 03, 2022

**Vijay Kumar Thota
Ref. No: 26606
MCV
Bangalore**

Dear Vijay,

Please refer to the project assignment letter dated **August 16, 2021** which was valid till **December 17, 2021**. In this regard we are pleased to inform you that the said assignment period has been extended till **July 04, 2022**.

You will be paid all inclusive stipend of **Rs. 10,000/- per month** effective from **04 January 2022**.

All other terms and conditions of services as specified in your assignment letter remain unchanged.

With best wishes,

For Tata Elxsi Limited

A handwritten signature in blue ink, appearing to read 'S. Rajagopalan'.

**Rajagopalan S.
Head – Human Resources**

Acknowledgement

I would like to thank CHRIST (Deemed to be University) Vice Chancellor, **Dr. Rev. Fr. Abraham V M**, Pro Vice Chancellor, **Dr. Rev. Fr. Joseph C C**, Director of School of Engineering and Technology, **Dr. Rev. Fr. Benny Thomas** and the Dean **Dr. Iven Jose** for their kind patronage.

I would like to express my sincere gratitude and appreciation to **Dr. K Balachandran**, the Head of Department of Computer Science and Engineering , School of Engineering and Technology , for giving me this opportunity to take up this project.

I am also extremely grateful to my guide, **Dr. Natarajan K**, who has supported and helped to carry out the project. His constant monitoring and encouragement helped me keep up to the project schedule.

I am also extremely grateful to my co-guide, **Mr. Deepak P**, who has supported and helped to carry out the project. His constant monitoring and encouragement helped me keep up to the project schedule.

I am extremely thankful towards TATA ELXSI for giving me the opportunity to carry out my project work in their esteemed organization. I am grateful to Mr. Deepak (Senior Engineer, TATA ELXSI), Mrs. Smitha Jagadeesh (Manager, TATA ELXSI), Prasanna V Balaji (Senior Engineer, TATA ELXSI) and all the associates at TATA ELXSI for their constant guidance, support valuable suggestions during the time of my project work. I also would like to thank all faculty members and non-teaching staff for their help and support. Lastly, I would like to thank each and every person who directly or indirectly helped me in the completion of the project, especially my parents and peers who supported me throughout my project.

Declaration

I, Hereby declare that the Project titled “**Compliance Automation Framework**” is a record of original project work undertaken by me for the award of the degree of **Bachelor of Technology in Computer Science and Engineering**. I have completed this study under the supervision of **Dr. Natarajan K**, Department of Computer Science and Engineering and **Mr. Deepak P**, Senior Engineer, Tata Elxsi.

I also declare that this project report has not been submitted for the award of any degree, diploma, associate ship, fellowship or other title anywhere else. It has not been sent for any publication or presentation purpose.

Place: School of Engineering and Technology, CHRIST (Deemed to be University), Bangalore

Date:

Name	Register Number	Signature
T. Vijay Kumar	1860416	

Abstract

Having access to a program that is capable of performing a scanning process in order to search for any of the weakness and then fixing these issues automatically is really precious to the security testing teams of the cybersecurity field. These tools drastically reduce the man-power that is required in order to perform security assessments and are also capable of automating the entire process in really great speed. But the only problem that comes into this picture is: the method of building an automated security assessment tool, that relies on security compliances.

According to a study, it is said that most of the cyberattacks happen due to a vulnerability or a bug in the system. This is one of the main reasons why an automated security assessment tool is important. As the number of bugs, as well as the type of bugs are increasing day-by-day, it has become important to choose the right tool for security testing and automation of these practices. The goal of the project is to automate compliance checks for various devices and systems. This covers the security testing, fixing the flaws in the security, as well as having a capability to undo the changes. For most of the systems, devices, and servers, the project uses the compliances provided by STIG (Security Technical Implementation Guide) and CIS (Center for Internet Security). STIG is one of the popular players in the field and is considered a bench-marker when it comes to setting up the rules and regulations in order to secure a type of system or a computer. We know a lot of tools that are really beneficial when it comes to security testing of systems. Developed framework will automate the compliance checking part in various devices, systems, servers and cloud platforms like AWS, Microsoft Azure etc. If a particular compliance is not being satisfied, then it is fixed automatically, and if any issues comes up after fixing the issue, the fix can also be reversed.

The main aim of this project is to provide a tool that is user friendly, as well as capable of automating the process of compliance checking and remediation of the issues that are detected during compliance checking. The tool is also capable of reversing the remediation process during the case of issues due to the remediation.

Keywords: STIG, CIS

Contents

CERTIFICATE	i
BONAFIDE CERTIFICATE	ii
INDUSTRY CERTIFICATE	ii
INDUSTRY CERTIFICATE	iv
ACKNOWLEDGEMENT	vi
DECLARATION	vii
ABSTRACT	viii
LIST OF FIGURES	xii
LIST OF TABLES	xiii
GLOSSARY	xiv
1 INTRODUCTION	1
1.1 Problem Formulation	2
1.2 Problem Statement & Objectives	3
1.3 Limitations	3
2 LITERATURE SURVEY AND REVIEW	5
2.1 Literature Collection & Segregation	5
2.2 Critical Review of Literature	8
3 ACTUAL WORK	16
3.1 Methodology for the Study	17
3.2 Feasibility Studies	18
3.2.1 Technical Feasibility	18
3.2.2 Economic Feasibility	18
3.2.3 Operational Feasibility	18

3.3	Hardware and Software Requirements	19
3.3.1	Hardware Requirements	19
3.3.2	Software Requirements	19
3.4	Software Requirements Specification	20
3.4.1	Users	20
3.4.2	Functional Requirements	20
3.4.3	Non-Functional Requirements	21
3.5	Overview of Development Phases	22
3.5.1	Inception	22
3.5.2	Planning	22
3.5.3	Development	23
3.5.4	Testing and Deployment	23
3.6	Experimental and Analytical Work Completed in the Project	24
3.6.1	System Architectural Design	24
3.6.2	Front-End	26
3.6.2.1	Technologies Used	26
3.6.3	Back-End	27
3.6.3.1	Technologies Used	27
3.6.4	Testing Framework	28
3.6.5	Source Code Management (SCM) and CI/CD	29
3.6.5.1	Technologies Used	32
3.6.6	Process Methodologies	32
3.7	Modeling, Analysis and Design	34
3.7.1	Design	34
3.8	Implementation	36
3.8.1	Project Structure	39
3.8.2	User Interface	40
3.9	Unit Testing	41
4	RESULTS, DISCUSSIONS AND CONCLUSIONS	43
4.1	Results & Analysis	43
4.2	Comparative Study	48
4.3	Discussions	49
4.4	Conclusions	50
4.5	Scope for Future Work	51
	BIBLIOGRAPHY	52
A	Appendix A Company	54
A.1	TATA ELXSI LIMITED	54
A.1.1	About Company	54

A.1.2 Services	55
--------------------------	----

LIST OF FIGURES

2.1	Ten levels of automation Courtesy: 'Agent Design Patterns for Assistance Systems in Various Domains' article.	7
3.1	Agile Methodology Courtesy: from 'Agile Model by javaTpoint' article.	17
3.2	Use Case Diagram	25
3.3	Snapshot of Dashboard	34
3.4	Code snippet of implementation of automation script	36
3.5	Code snippet of implementation of automation script	37
3.6	Code snippet of implementation of automation script	37
3.7	Code snippet of implementation of automation script	38
3.8	Code snippet of implementation of automation script	38
3.9	Code snippet of implementation of automation script	39
3.10	Dashboard	40
4.1	Dashboard of framework	44
4.2	Compliances available in framework	44
4.3	Remediation available in framework	45
4.4	Rollback available in framework	46
4.5	Device Management	47

LIST OF TABLES

3.1	Hardware Requirements	19
3.2	Software Requirements	20
3.3	Non-Functional Requirements	22
3.4	Unit Tests for the GUI	42

GLOSSARY

Item	Description
OS	Operating System
STIG	Security Technical Implementation Guide
CIS	Center for Internet Security
CSC	Critical Security Controls
CLI	Command Line Interface
GUI	Graphical User Interface
DUT	Device Under Testing
SQL	Structured Query Language
HTML	Hyper Text Markup Language
CSS	Cascading Style Sheets
IT	Information Technology
CPU	Central Processing Unit
RAM	Random Access Memory
SCM	Source Code Management

Chapter 1

INTRODUCTION

Compliance scanning focuses on the configuration settings (or security hardening) that are applied to a system. In a word, compliance scans assess adherence to a specific compliance framework. Hardening is the process of implementing security recommendations from multiple compliance frameworks that apply to a firm or an organisation. For example, it might be needed to have a 8 digit password with special characters to make sure that the password of the system is strong enough. A compliance scan can be used to verify that the security of a system is good and hardened. When a compliance scan is run on a single computing system, a report is generated that shows how good is the security after following a particular compliance to strengthen its security. These findings demonstrate the system's overall security. By integrating the compliance scan reports/results of all systems, you can determine the overall security posture of your system and/or infrastructure.

The significance and goal of this project is to provide a user-friendly application that can assist and automate the process of compliance verification and remediation in order to assure device, server, and cloud platform security.

The Compliance Automation Framework aids in the automation of the compliance inspection and remediation process, making it easier, faster, and more reliable. Compliance Automation Framework makes use of an open-source framework that is a strong tool for creating compliance and remediation automation scripts. It generates thorough reports after the compliance check. Scrum masters can use these reports to keep track of faults and flaws as well.

1.1 Problem Formulation

Companies are finding it more difficult to manage the quality of their software applications as technology advances. Process adherence and process evaluation typically receive less attention than they need due to the tight time window in agile development and economic considerations, and security takes a backseat.

The common misunderstanding of compliance scanning stems from two concerns with vulnerability scanning.

First, many people identify vulnerability scanning with issues discovered when scanning a system for flaws that can be exploited by others (i.e. hackers) to compromise the system's security. This mindset is no doubt influenced by the quantity of malware that exploits these flaws and has plagued computer system and user security for years. While this association is reasonable, it falls short of capturing the full extent of the problem because vulnerability management covers more than the discovery of exploitable weaknesses in systems.

Second, Without distinguishing the type of vulnerability (such as software, personnel, organisational, or compliance), security professionals have a propensity to put all vulnerabilities under one umbrella term (vulnerability). As a result, many people revert to the above-mentioned classic concept of vulnerabilities and vulnerability scanning. As a result, their vulnerability scanning emphasis narrows dramatically, allowing other types of vulnerabilities to sneak through the gaps.

Lack of effective compliance evaluation leads to higher expenses and a negative impact on software compliance. An unexpected test management approach, a development delay, or an underestimation of the effort required to create a test case could all be contributing factors. Engineers undoubtedly do their utmost to catch faults or flaws before delivering a product. However, the harsh reality is that you can't capture every bug! As a result, using an automated programme can help you avoid many of the issues listed above. The Compliance Automated Framework attempts to automate the compliance inspection and remediation process in order to make it easier, faster, and more reliable.

1.2 Problem Statement & Objectives

To build a automation tool which contains the capabilities of analyzing and preventing security threats from various known platforms. The project is proposed to have a CLI based, and a GUI based interface for performing the compliance checking. The project is focused on checking different rules and protocols to make sure the system meets all the standards in terms of security. The most significant advantage of the tool is improved accuracy, ease of tracking and time savings when compared to manual processing. The major objectives of the project are as follows -

- To understand the basics of security assessment.
- To understand and implement various prevention techniques against various security attacks.
- To prevent and analyze various security threats

1.3 Limitations

This is a client ordered project and has its own limitations with respect to time, accessibility and other constraints. Also, there might be other limitations of the project work depicted in the report that may not be obvious. This is an ongoing project and it mainly focuses upon improving the security configuration of different softwares, Operating systems, servers and devices by evaluating process compliance and standards it follows and thereby reducing the amount of manual work and time spent. As we go deeper into the software tool there are many more features that can be added such as extending support to more departments, adding more number of standards in security field. Some of the major limitations identified regarding the project are -

- The project needs to be coded and extended for each standard to be followed. These may vary from department to department and the product itself.
- The project as of now only supports single DUT device configuration.

- There is an evident drop in performance with respect to time when the number of DUT devices connected are high.
- A lot of technical details like server name, code review server details and repositories etc are required in order to add a project for evaluation. Managers who are not familiar with such details of the project might find it difficult to use the tool.
- The tool is developed in such a way that very little flexibility is allowed for a project. Even if there are only minor changes from the required standards the tools will evaluate the project as non-compliant.
- This study majorly considers and analyzes the articles published with the purpose of improving the quality or productivity of software.

Chapter 2

LITERATURE SURVEY AND REVIEW

In almost every new software development project, security is a key procedure. Process adherence is concerned with not only ensuring that the product performs properly in accordance with the organization's requirements, but also that it is bug-free. The main goal of the Compliance Automation Framework is to create a user-friendly solution that may help and automate the process of compliance checking and remediation, making it easier, faster, and more reliable. The project's goal is to evaluate and automate the processes that must be followed in order to make compliance inspections and remediation faster, easier, and more reliable. This chapter is separated into two parts. Namely:

- Literature collection and segregation (called as literature survey – collection of data)
- Critical review of selected literature (from the ones collected during the survey)

The first sub-chapter is very straight forward to understand and perform. However, more emphasis is given to the second sub-chapter – Critical review.

2.1 Literature Collection & Segregation

The literature review and backdrop of the system study will be the emphasis of this chapter. It aids in the identification of existing system flaws as well as the optimal strat-

egy for attaining the objectives. It will discuss the tool's compatibility with existing systems. Regulatory compliance has become the primary focus of information technology (IT) spending for many firms. More money is spent on complying with regulations than on defending against security threats and meeting corporate needs [1].

Compliance inspection has always played an important role. This is another role that has evolved quickly. Compliance Automation has evolved from being primarily responsible for process compliance to now actively participating in strategic corporate governance. The main purpose of the Compliance Automation Framework is to evaluate and automate the compliance processes that are followed, making compliance checking and remediation easier, faster, and more reliable [2]. To guarantee that the established processes and standards are followed. Process monitoring and audits are commonly used to assess compliance with agreed-upon standards and processes. Non-compliance issues could be escalated as needed through an independent reporting channel to the appropriate level that organisational management allows. Noncompliance concerns are issues discovered during audits that show a failure to follow applicable standards, process descriptions, or procedures [4].

Many aspects of software engineering are now automated, including requirements definition, architecture, implementation, modelling, testing and quality assurance, verification, and validation. These studies focus at how to improve software quality and productivity by using semi-automated and fully automated approaches in software engineering evaluation and development. Automation has been applied in a variety of ways.

Automation is now used in many areas of software engineering, including requirements definition, architecture, implementation, modelling, testing and quality assurance, verification, and validation. These studies look at how to employ semi-automated and fully automated methodologies to software engineering evaluation and development to increase software quality and productivity. Automation has been used in many different ways. Automation can be defined

- Automatic control of the manufacture of a product through a number of successive stages;
- The application of automatic control to any branch of industry or science;

- By extension, the use of electronic or mechanical devices to replace human labor.

Automation (partially or totally) in various control systems, technology, and processes is used to reduce the need for human intervention. Operators can employ automated equipment to implement control processes. Information acquisition, information analysis, decision and action selection, and action implementation are four major categories of functions that can be automated [12]. It refers to the complete or partial replacement of a function previously performed by a human operator, implying that automation is not all or nothing, but can range from entirely manual to fully automated.

Figure 2.1 shows a 10-point scale, with higher levels representing increased autonomy of computer over human action, based on a previously proposed scale. Software process compliance automation is just what the phrase implies: the automation of compliance processes that previously had been done manually, by employees.

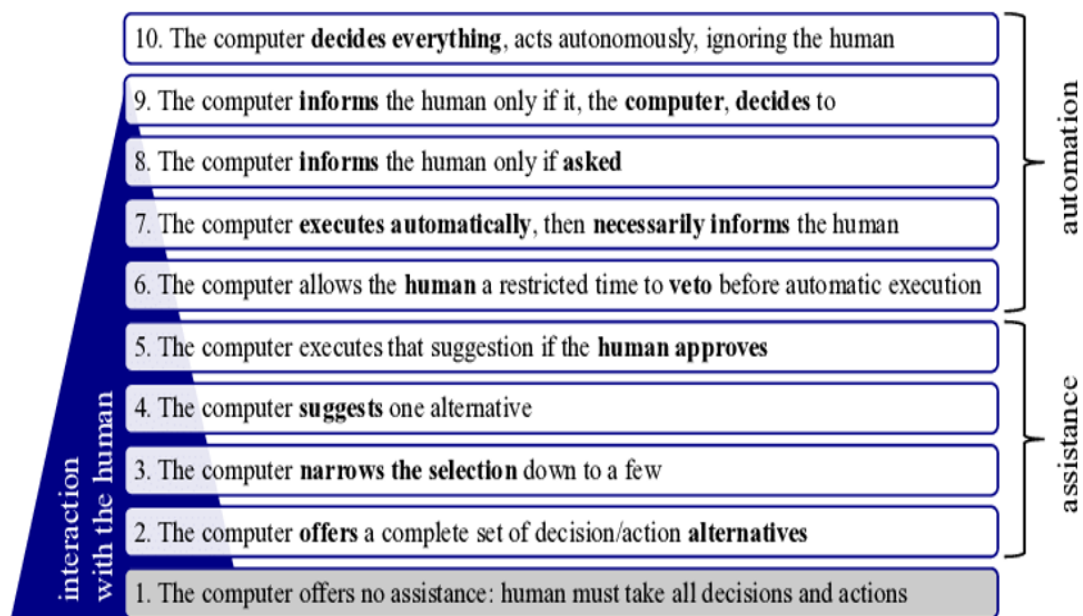


FIGURE 2.1: Ten levels of automation

Courtesy: 'Agent Design Patterns for Assistance Systems in Various Domains' article.

The software executes the compliance tests and review process from start to finish using automation technology. Compliance teams put the solutions in place, then monitor and evaluate the results. Compliance experts can use compliance automation to reduce the risk of non-compliant conduct while also increasing the projected return on an organization's compliance strategy, planning, and training investments.

2.2 Critical Review of Literature

This chapter will compare and contrast the tool, the technology it employs, and existing systems. Regulatory compliance has become the primary focus of information technology (IT) spending for many firms. More money is spent on complying with regulations than on defending against security threats and meeting corporate needs. Compliance inspection has always played an important role. This is another role that has evolved quickly. Compliance Automation has evolved from being primarily responsible for process compliance to now actively participating in strategic corporate governance [3].

In the Paper Security Compliance Analysis of Reconfigurable Scan Networks I learned a that Hardware security provides a new layer to the design space, and circuits are increasingly being protected against attacks like as sniffer, spoofing, and IP theft. However, all of a designer's security precautions could be undone if infrastructure for testing, diagnosis, and reliability management is later included. Access techniques such as reconfigurable scan networks (RSNs) in particular may provide opportunities for side-channel attacks. A precise estimation of reachability qualities of all considered benchmarks is provided using the presented approach. The method compares the original and upgraded designs' reachability using a matrix-based approach. Configuring a single scan path as well as many successively active scan paths through the RSN causes complicated functional dependencies, which are covered by the reachability analysis[2].

The Paper The design and implementation of an automated security compliance toolkit was about the demand for preserving the security, integrity, and privacy of corporate and consumer information is growing at an unprecedented rate, thanks to government laws. Various automatic and human controls are used by the government and private enterprises to comply with these rules. This paper presents an automated security compliance toolkit that was designed and developed using mostly open source tools to show that 1)meeting regulatory compliance does not have to be an expensive proposition, and 2)a project of this magnitude could be used as a pedagogical exercise for students studying collaboration, project management, software engineering, information assurance, and regulatory compliance[4].

The Paper Towards Building an Automated Security Compliance Tool for the Cloud talks about Security, particularly security compliance, is a primary worry that is delaying large-scale organizational adoption of cloud computing. Enterprises need particular

degrees of security compliance from cloud providers for a variety of reasons, including government mandates, business requirements, and trust. Until now, security compliance or auditing data has been manually generated by security specialists. This requires manual data gathering and analysis, which is time-consuming and costly. As a result, an automated security compliance tool (ASCT) is required to check and express the compliance of different cloud providers. By automatically confirming compliance, such a solution can reduce human intervention and, as a result, cost and time. The tool will also allow cloud suppliers to be more transparent with their customers[6].

They created an architecture to build an ASCT for a cloud computing platform with these goals in mind. They've also detailed four different ways to do this automation. These four possible ways include API, vulnerability scanning, log analysis, and manual entry, which are four data gathering mechanisms for collecting data from cloud services.

Finally, based on the proposed design, they developed a proof-of-concept prototype of this ASCT. The CloudAudit API is used to expose the findings of the prototype's integration with the OpenStack cloud platform.

It was talking about an architecture for building an ASCT for cloud in this work. We began with a high-level abstract design that identified what needed to be done in order to construct the system. The scientific effort opens up new avenues to investigate. During the project, we investigated how to automatically monitor the compliance state of the cloud platform, rather than the virtual machines that run on it. Verifying the security compliance of virtual machine instances running on the cloud with relevant standards will be a new area of research. The scientific effort opens up new avenues to investigate. During the project, they investigated how to automatically monitor the compliance state of the cloud platform, rather than the virtual machines that run on it. Verifying the security compliance of virtual machine instances running on the cloud with relevant standards will be a new area of research.

Many of the controls outlined in the standards require human input, and some of them may not be able to automate at all, as we discovered while analyzing the standards. Physical security controls, for example, are exceedingly difficult, if not impossible, to automate. Another point to consider is that some controls may only be partially automated, requiring human participation for the remainder of the process. One of our aims

in this project is to look at different ways of collecting data from the cloud, and we've discovered four different ways to do so. The adoption of a vulnerability assessment system is one way we believe is particularly significant (VAS).

One reason is that a VAS is intended to detect flaws in computers, computer systems, networks, or applications. The VAS takes data from the system to do this assessment, which we want to accomplish here as well. Today, VAS tools may perform tasks like as high-speed discovery, configuration auditing, asset profiling, sensitive data detection, patch management integration, and policy verification. The PCI DSS compliance assessment for LAMP (Linux, Apache, MySQL 1592, and PHP) servers is already supported by a proprietary VAS tool named Nessus . All of these projects are in line with our efforts to automatically verify compliance.[6].

In the paper Security Compliance: The Next Frontier in Security Research which talks about IT security research has failed to generate meaningful solutions to escalating security concerns, according to both practitioners and researchers. This failure is attributed to the fact that IT teams no longer value security as a goal. Rather, funds are being spent on technology that enable security requirements to be met.

Academia has yet to embrace this shift in mindset, and it continues to try to "sell" security to companies looking to "purchase" compliance. Since of this gap, research has failed to improve real-world security because it has not been accepted by the market. The conclusion reached in this work is that new research into security compliance is needed to supplement present security research. More work in this relatively new direction should be encouraged[7].

In the paper Compliance with Information Security Policies: An Empirical Investigation talks about a major threat is when an organization's own personnel fail to follow its information security policies. Developers have proposed many policy-compliance solutions to guarantee that employees respect their organizations' security standards. According to previous research, these metrics lack empirically verified principles to ensure that personnel follow them. This poses a critical flaw because practitioners want empirically validated instructions to improve their employees' compliance with information security regulations[8].

According to the literature, the biggest threat to information security is negligent personnel who don't follow the company's information security rules and procedures. While previous research has proposed numerous methods for ensuring employee compliance with information security policies, these methods have been critiqued for missing empirically established principles. This is a critical flaw, because practitioners in businesses need strong, empirically validated data on how to enhance their employees' adherence to information security standards.

They performed a survey based on strong behavioural theories to better understand why some employees follow information security regulations while others do not. Employees' intentions to comply with security regulations are influenced by social pressures from peers and superiors, their perception of the effectiveness of these policies in preventing information security threats, and the visibility of these policies, according to our findings. Furthermore, employees' perceptions of their organization's vulnerability to information security risks, as well as the immediacy of such dangers if no countermeasures are taken, have a substantial impact on employees' willingness to follow information security policies.

Using pertinent theory-based and literature-supported predictors, this study gave a comprehensive picture of the characteristics that predict employees' desire to comply with information security policies—but with a twist: Intuitively, the small association between rewards and real adherence to information security standards does not make sense. This negligible link may be due to the fact that in firms in general, and in the organizations analyzed in particular, rewards are rarely applied for security compliance. Our findings, taken combined, contribute to the empirical prediction of why employees follow or ignore information security regulations and procedures. As a result of our research, a more detailed prediction of this phenomenon in the future should be possible.

The rise in data security breaches in recent years—along with the existing substantial financial and other ancillary costs associated with such breaches—clearly favours any endeavour to improve the quality of such prediction while also assisting enterprises in lowering these costs.

To solve this flaw, we conducted a poll based on sound behavioural theories to learn why some employees follow their employers' security regulations while others do not. Our Organizations require social pressure, according to research employees' peers and

supervisors to urge them to adhere to security policies. As a result, it is critical. compliance with information security policies is emphasized by management, information security professionals, and peers.

Furthermore, reliable assessments of their organization's information security vulnerabilities threats—and the immediacy of such dangers if no countermeasures are taken—have a substantial impact. effect on employees' willingness to follow security procedures policies.

Furthermore, the visibility of information security has an impact. on the employees' willingness to follow established policies. As a result, a strong message emphasizing the necessity of compliance should be prominently displayed throughout the organization. company. Information security campaigns, banners, and coffee mug adverts can all help. All of these things aid visibility. Managers and IT security personnel must state the penalties for not adhering to security policies. Employees, in particular, must realize that violation with these policies will be recognized and punished. They will face serious consequences very soon.

Many organizations have experienced increases in information security incidents over the past few years. A 2002 survey by the United Kingdom Department of Trade and Industry revealed that 44 percent of UK businesses had suffered at least one malicious security breach in the past year.¹ A 2008 survey by the US's Computer Security Institute divulged that about 50 percent of the respondents' corporations had between one and five security incidents during the past year, an estimate that has remained fairly steady over the past four years. To cope with increased information security threats, various technical protection means, such as antivirus software tools and information security policies,² have been suggested in the literature. Unfortunately, employees seldom comply with these techniques and policies.

Employees' noncompliance with information security policies is exemplified by their usage of easy-to-guess passwords. Another example is writing passwords on sticky notes and keeping them in conspicuous areas in the office or at home. Such irresponsible employee activity jeopardises an organization's assets and reputation. Employee compliance with security policies has been the subject of several studies. These studies cover a wide range of topics, including security awareness training and the application of social psychology to improve employees' information security behaviour. To ensure

that employees obey information security policies and standards, need-based theories have been proposed.

While these studies offer fascinating principles for enhancing information security awareness, none of them provide actual evidence to back up their claims.

In this paper Computer Security Division-Computer Security resource Center which basically talks about the The National Institute of Standards and Technology's Computer Security Division maintains and updates the Computer Security Resource Center (CSRC) (NIST). [9]

The Computer Security Division's Web site is the Computer Security Resource Center (CSRC). CSRC is one of NIST's four most popular Web pages. We use the CSRC to promote widespread sharing of information security technologies and practices, to serve as a resource for information security standards and guidelines, and to identify and link to significant security Web resources to help the industry. The CSRC is an important part of all we do and accomplish. It is our repository for anyone seeking access to our documents and other information security-related information, whether public or private.

In the paper Security Guidance for Critical Areas of Focus in Cloud Computing v4.0 which basically talks about the expanding technology, cloud computing presents a number of benefits and concerns. Cloud computing, including the ubiquitous Internet of Things, is now becoming the back end for all sorts of computing. The information security industry is built on the foundation of cloud computing. Containerization and DevOps are two new ways of arranging compute that are inextricably linked to cloud and propelling our revolution. With this document, we hope to provide both direction and inspiration for achieving corporate objectives while controlling and mitigating the risks associated with cloud computing adoption[13].

This domain serves as the foundation for the rest of the Cloud Security Alliance's recommendations. It defines and discusses cloud computing, establishes our baseline language, and explains the logical and architectural frameworks that will be used throughout the paper. There are numerous perspectives on cloud computing: To mention a few things, it's a technology, a set of technologies, an operational model, and a business

model. It's fundamentally transformational and disruptive. It's also developing at a breakneck pace with no indications of slowing down. While the reference models given in the initial version of this Guidance are quite realistic, they are far from full. Even this update won't be able to account for every possible change[13].

Cloud computing has a lot of potential in terms of agility, reliability, and cost savings. Organizations can move more quickly because they don't have to buy and provision hardware. Everything is software defined), reduce downtime (due to inherent elasticity and other cloud features), and improve security. While also saving money (because to lower capital costs and increased demand and capacity). Because cloud providers have large financial incentives, we also observe security gains. However, these advantages will only surface if you comprehend and apply cloud-native models, as well as make necessary adjustments.

The purpose of this domain is to lay the groundwork for the remainder of the document and its recommendations. The goal is to establish a shared language and understanding. Begin stressing the distinctions between cloud and traditional computing for security experts, and traditional computing, as well as assisting security professionals in the adoption of cloud-native technologies.

Techniques that, rather than increasing risks, result in increased security (and other benefits). The Cloud Security Alliance encourages the use of best practices for delivering security assurance in the cloud computing sector and has created a practical, actionable road map for businesses interested in adopting the cloud paradigm. The fourth version of the Cloud Security Alliance's Security Guidance for Critical Areas of Focus in Cloud Computing is based on prior revisions, focused research, and public input from Cloud Security Alliance members, working groups, and industry experts. This edition incorporates improvements in cloud, security, and supporting technologies, as well as real-world cloud security practices, the newest Cloud Security Alliance research initiatives, and technology guidance[13].

The main purpose of the Compliance Automation Framework is to evaluate and automate the compliance processes that are followed, making compliance checking and remediation easier, faster, and more reliable. Instead of being a one-time project, a good compliance framework should connect people, business cycles, and IT in a way that is essential to the organization's ongoing business operations [9].

The Compliance Automation Framework's primary goal is to assess and automate compliance activities, making compliance monitoring and remediation easier, faster, and more reliable. A effective compliance framework should connect people, business cycles, and IT in a way that is critical to the organization's continuing business operations [9], rather than being a one-time effort.

A collection of IT tools that automatically track regulatory compliance is an important aspect of an efficient compliance framework. Furthermore, IT apps can help teams from all parts of the company use compliance-related measures and controls to discover and improve inefficient internal business and technology controls on a constant basis. The ability to integrate all of the devices and data - across all relevant regulations and a uniform set of actionable IT controls - to deliver a unified view of compliance is a fundamental challenge for test organisations in the current compliance environment. Internal auditors can address this issue because they have a deeper view of the organization's compliance initiatives' overall stability [10]. Inner examiners can address this difficulty since they have a more extensive perspective on the general soundness of the association's compliance endeavours. Unlike any other software evaluation system, the Compliance Automation tool employs Atlassian Jira management software in conjunction with the project to assess process adherence. Organizations typically have their own standards and processes in place for each department, which are used to design projects.

Chapter 3

ACTUAL WORK

The project is being completed utilising the Agile methodology, which is a quick and nimble approach to meeting the project's objectives. The project's purpose is to develop software that will help the business evaluate and track software project process adherence. Before the actual project work could begin, there were a few chores that needed to be accomplished. Some of these items include distributing responsibilities among the team, understanding the resources that will be used, studying the procedures that will be employed in the creation of this project, and so on. Understanding the back-end and front-end code bases, as well as the expectations of clients and stakeholders, was crucial.

Before beginning the projects, make a comprehensive assessment of everything and of all required technology was conducted in order to make efficient use of it. Several modules were used in the project to achieve the objectives described. This chapter is broken down into :

- Methodology for the Study
- Feasibility Studies
- Hardware and Software Requirements
- Software Requirements Specification
- Overview of Development Phases
- Experimental and Analytical Work Completed in the Project

- Modelling, Analysis and Design
- Implementation
- Prototype and Testing

3.1 Methodology for the Study

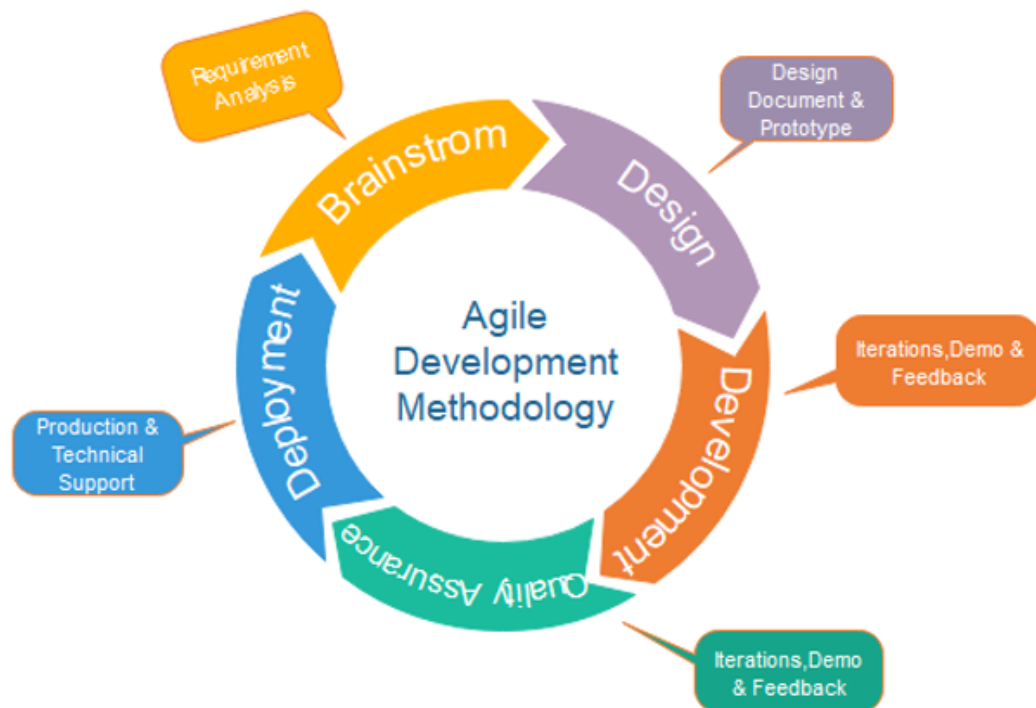


FIGURE 3.1: Agile Methodology
Courtesy: from 'Agile Model by javaTpoint' article.

The project's principal methodology is the agile development strategy. Agile methodology has recently gained popularity due to its improved performance and ease of client delivery. In comparison to other techniques, the Agile model has proven to be effective and satisfactory in terms of meeting customer expectations because clients are actively involved in the development process. The models' performance and outcomes are expected to appeal to the project's stakeholders.

The major goal of the project is to apply the Agile Development approach to fulfil the defined goals. Experimentation and consistency tests were both considered. The

efficacy of a methodology to a specific problem statement can only be evaluated and concluded when it achieves its objectives with sufficient precision. This is possible if the software is well-designed to meet the goals.

3.2 Feasibility Studies

Feasibility study talks about whether the solution is feasible in basically three aspects namely:

- Technical Feasibility
- Economic Feasibility
- Operational Feasibility

3.2.1 Technical Feasibility

The points below will help conclude that Compliance Automation Framework is technically feasible :

- The back end is developed using Python
- The requirement mainly software and hardware requirements are easily procurable as they are open source.
- File systems are used as data stores.

3.2.2 Economic Feasibility

Compliance Automation Framework is economically feasible as the tools used to design and develop this dashboard are either open source or copyrighted within TATA ELXSI.

3.2.3 Operational Feasibility

Compliance Automation Framework is operationally feasible as all the intended functionalities are achieved.

3.3 Hardware and Software Requirements

This section outlines minimum software and hardware requirements for deploying Compliance Automation Framework. Requirements may vary based on utilization and observing performance of this projects is recommended prior to scale out.

3.3.1 Hardware Requirements

Usage of CPU, RAM, and storage space can vary significantly based on user behavior. These hardware recommendations are based on traditional deployments and may grow or shrink depending on how active users are. Most small to medium deployments can be supported on a single server with the following specifications based on registered users:

TABLE 3.1: Hardware Requirements

Processor	3.0 GHz(Recommended)
RAM	8 GB (Recommended)
Hard Disk	30 GB
Keyboard	104 Keys
Display	VGA (Video Graphics Array)

3.3.2 Software Requirements

Software requirements describes the requirements of tools, frameworks and software that are the prerequisite for running Compliance Automation Framework. Below the required tools and software that are required for Compliance Automation Framework to run is specified :

TABLE 3.2: Software Requirements

Operating System	Windows/Kali Linux or any other form of Linux
Software required	STIG Viewer, VMware, Inspec Open-source tool, Visual Studio
Front-End	HTML 5, Ajax, ReactJS, JavaScript
Security	B-Crypt algorithm for encrypting user data

3.4 Software Requirements Specification

3.4.1 Users

This Application is designed and developed in such a way that it has various types of users and accesses which are Associates, Email-Recipients and Developers.

- Associates :
Associates include scrum masters, project managers, team leads and developers. They have access to the end system and have the functionality to add projects, evaluate projects and track results.
- Email-Recipients
While adding a project for evaluation several stakeholders can be notified about the evaluation results and tracking updates by adding them to the email recipient list.
- Testers and Maintainers :
They have additional privileges compare to other associates using which they can create test data to mock projects and find vulnerabilities.
- Developers :
Developers are the most privileged and has access to all the features offered by the system.

3.4.2 Functional Requirements

Functional requirements will describe what a system must do. The functional requirements for this framework are:-

- **Compliance Scanning :**

This function checks for the compliance of a particular profile. Based on the compliances, it is checked if the device is up to the mark in terms of the security of the device.

- **Remediation:**

After the compliance scanning is complete, if a particular scanning is complete, if a particular vulnerability is detected, then vulnerability is patched with the 'remediation' functionality, where the respective script would fix the issue.

- **Rollback:**

After particular remediation, if certain issues are caused, then rollback functionality acts like an undo button to revert back the changes made during the remediation.

- **Device Management:**

This is required to add, remove and manage the devices which are connected to the host machine for testing purposes.

- **Update STIG/CIS file:**

This is required to update the compliances of the profiles to keep up with the latest version of the compliance that is available in the market.

3.4.3 Non-Functional Requirements

Non-Functional requirements describes how the system works. The functional requirements for this framework are :

TABLE 3.3: Non-Functional Requirements

Non-Functional Requirements	Descriptions
Non-Functional Requirement-1	Security: The user credentials that are used to login to the tool must be protected and encrypted using a strong algorithm.
Non-Functional Requirement-2	Reliability: The data entered into the tool should be checked for correctness and inconsistencies.
Non-Functional Requirement-3	Availability: Data should be backed up and hence in case of a crash the <u>backed up</u> data can be used.
Non-Functional Requirement-4	Documentation: The Documentation has to be maintained throughout

3.5 Overview of Development Phases

3.5.1 Inception

The organisation provided information on different project kinds and the standards that are followed. The information gathered was then put together into an usable explanation of how the data could be used and processed.

3.5.2 Planning

During the planning phase, the information obtained in the previous phase was analysed. This aided in better understanding the requirements and planning the project's front end, backend, and features. The extracted standards and the evaluation outcome based on these standards will be linked.

3.5.3 Development

Following the planning phase, all of the plans were carried out, including project development and coding. The interface, backend, and other capabilities were designed in accordance with each module's plan. It was ensured that the strategy was followed and that the development did not deviate or slow down during the development phase.

3.5.4 Testing and Deployment

Each artefact is evaluated independently in order to swiftly discover and change the aspects in order to produce the most effective final result. There were no big issues because most of the components had already been evaluated.

3.6 Experimental and Analytical Work Completed in the Project

It required a lot of research and thought to narrow down the tech stack that will be used for the project. This section describes the general system architecture of the project as well as the reasons for the technologies and frameworks selected.

3.6.1 System Architectural Design

During the creation of this project's architecture, a lot of effort was put in. Finally, after much effort and meticulous preparation, we were able to identify the project's architecture. During the scanning and remediation phases, the application will be utilised by a single user and will function as stand-alone software. The diagram below will help you understand the program's architecture:-

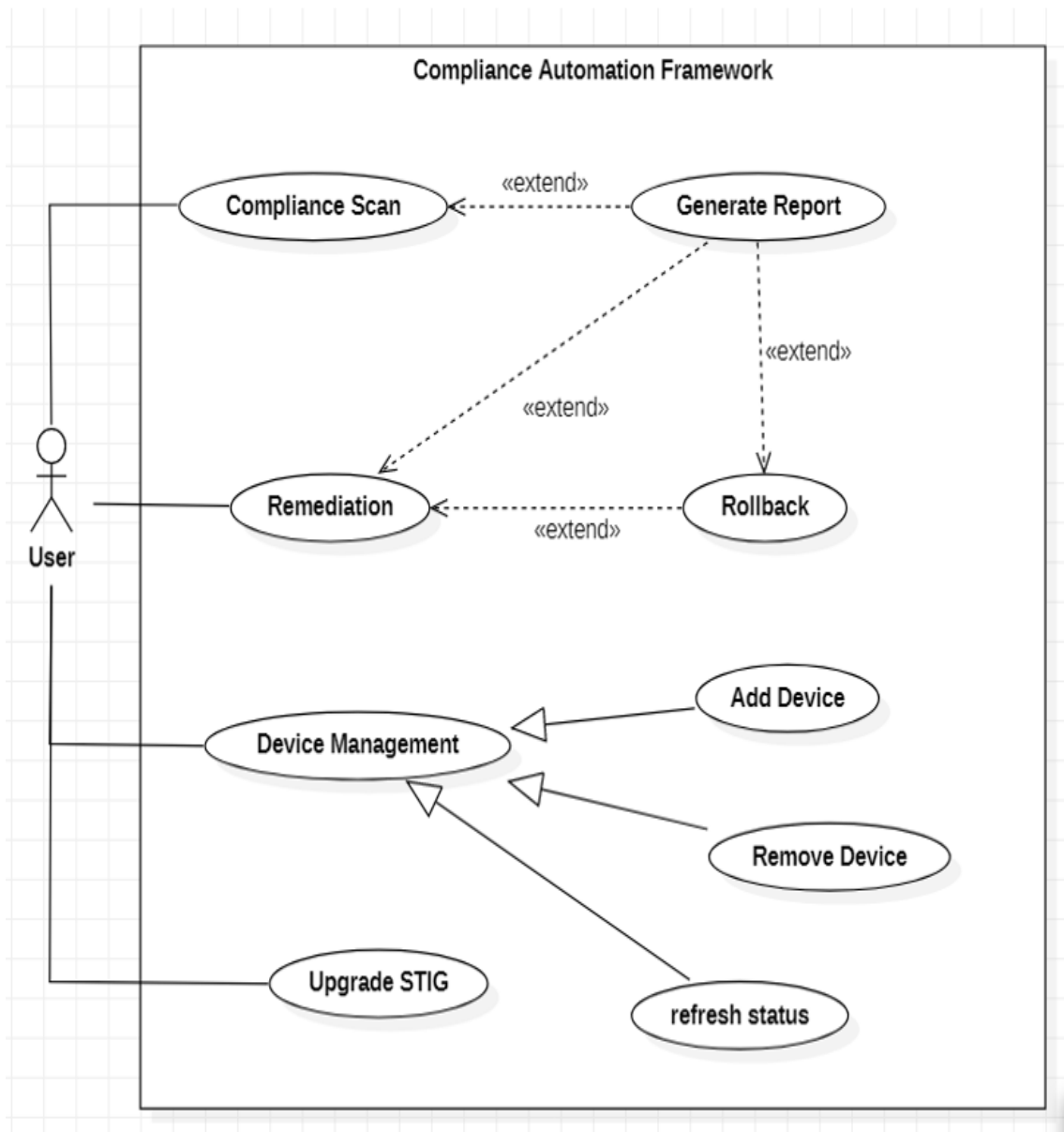


FIGURE 3.2: Use Case Diagram

The user can interact with many functionalities, as shown in the above Use Case Diagram: Compliance Scan, Remediation, Rollback, Device Management, and Up-grade STIG. Each feature has its own purpose. The main goal is to run automated compliance checks for various devices and then use the scripts for each vulnerability to address the vulnerabilities and flaws discovered in the devices.

3.6.2 Front-End

Front-End Development is also called client-side development which is developed using HTML / CSS / Bootstrap / JavaScript which helps users to interact with the website, the more responsive the more user friendly is the website. The front end web development is done as it is one of the important interfaces of the project. They run in the web browser such as chrome, internet explorer.

Importance of front-end

Business enterprises require websites and applications, the front-end allows the website to make it more responsive.

3.6.2.1 Technologies Used

- **HTML and CSS**

HTML (Hypertext Markup Language) and CSS (Cascading Style Sheets) are two of the most widely used technologies for creating Web pages. HTML offers the page structure for a variety of devices, whereas CSS provides the (visual and aural) layout. The basis for developing Web pages and Web apps include HTML and CSS, as well as graphics and scripting. HTML is the language that describes the layout of Web pages. HTML is used by developers to perform the following:

- Publish online documents with headings, text, tables, lists, photos, etc.
- Retrieve online information via hypertext links, at the click of a button.
- Design forms for conducting transactions with remote services, for use in searching for information, making reservations, ordering products, etc.
- Include spread-sheets, video clips, sound clips, and other applications directly in their documents.

Authors use markup to explain the layout of pages in HTML. The language's elements designate content types such as "paragraph," "list," "table," and so on. CSS is a language for explaining how Web pages are presented, including colours, layout, and fonts.

It enables the presentation to be adjusted for various types of computers, such as large screens, small screens, or printers. CSS can be used for any XML-based markup language and is not dependent on HTML. The separation of HTML and CSS makes it easier to manage websites, share style sheets across pages, and customise pages for different situations.

- **JavaScript**

JavaScript is a text-based programming language that helps you to make inter-active web pages on both the client and server sides. Whereas HTML and CSS provide structure and design to web pages, JavaScript adds interactive elements that keep users engaged. Although it is best known as a scripting language for Web sites, it is also used in a variety of non-browser environments, including Node.js, Apache CouchDB, and Adobe Acrobat. JavaScript is a single-threaded, prototype-based, dynamic language that supports object-oriented, imperative, and declarative (e.g. functional programming) programming types.

3.6.3 Back-End

The term "back-end development" refers to the activities on the server-side. It revolves around databases, pre-planning, and site engineering. It includes behind-the-scenes activities that occur while performing some task on a website. To complete back-end work, back-end developers use languages such as Java, PHP, Ruby on Rails, Python.

3.6.3.1 Technologies Used

- **Python**

Python is a high-level, interpreted and general-purpose programming language. It is an easy-to-implement language, where the developer does not have to worry much about the coding complexity but instead focuses on getting the work done with the language. It is really simple to use python, and can also be applied for backend technologies. Some of the top features of Python are:-

- **Easy to code:** It is really easy to learn and code in python language as compared to other languages such as java. This is due to the reason that python is a developer-friendly language.
- **Free and Open Source:** Python is a freely available language and is available for free download at its official website.
- **Object-Oriented Language:** Python is capable of applying object-oriented coding structure and supports the concepts of classes, objects and encapsulation.
- **GUI Programming Support:** Apart from the countless great features, another good feature of python is that it supports GUI Development with modules such as PyQT5 and wxPython.
- **High-Level Language:** When we write a program in python, we don't need to remember the system architecture or about managing the memory. All this is automatically done by Python.

• SQL

SQL is a programming language which is used for holding and managing databases. The data is held in a relational database management system. In this project, SQL is being used to store some parts of the data which is reflected in the processing of the compliance scanning and device management.

3.6.4 Testing Framework

Through critical analysis, software testing identifies and evaluates if the generated application fits the Business Requirement Specifications. The Software Testing Lifecycle (STLC) is a never-ending procedure that runs parallel to the software development life cycle. At each stage, it verifies the app's functionality and validates the app's output against the criteria. In addition to delivering bug-free software, software testing helps to improve the functionality and usability of programmes. Software testing can take many different shapes, methodologies, and techniques, as well as different verification and validation levels.

Importance of Software Testing

Software testing ensures that the product is of good quality and that the customers and users are happy. It claims to improve corporate efficiency (reduced maintenance costs), reliability, and user experience. Despite the efforts of designers and developers, software testing is crucial to the development process. Overall, delivering an exceptional product demands an ongoing verification and validation process. The system/performance applications and quality are defined at each step of the test. As a result, it can be used to see if a software application meets both technological and business needs. The importance of software testing is evident in the final quality assurance report. If the final products pass the various phases of testing, they may perform better than expected. Testers can participate in each stage.

3.6.5 Source Code Management (SCM) and CI/CD

• Source Code Management (SCM)

Source code management (SCM) is a technique for tracking changes to a source code repository. SCM keeps track of a code base's history of changes and assists in resolving conflicts when merging updates from various contributors. SCM is also referred to as version control. As the number of lines of code and contributors on a project grows, so do the expenses of communication overhead and management complexity. SCM is a vital instrument for reducing the strain on organisations caused by rising development expenses.

The importance of source code management tools

Making updates to a shared piece of code is a regular occurrence when numerous developers are working within a shared codebase. Separate developers can be working on a seemingly isolated feature, however this functionality could be using a shared code module. As a result, developer 1 working on Feature 1 may make certain changes only to discover later that Developer 2 working on Feature 2 made changes that clash. Version Control is the duty of SCM as a safety measure against this specific circumstance. Version control protections were added to SCM to prevent work loss due to conflict

overwriting. These measures function by tracking and recognising changes made by each individual developer.

SCM will then notify the developers of these points of contention so that they can safely evaluate and resolve them. This basic conflict resolution process also serves as a form of passive communication for the development team. After then, the team can monitor and discuss the work in progress that the SCM is keeping track of. The SCM keeps track of all modifications to the code base over time. This enables developers to investigate and review adjustments that may have resulted in problems or regressions. There are several reasons why we should manage the source code that we write:

- **Work together in teams.** A source code management system allows multiple developers to access and change different areas of the code, without interfering with each other's work. This is a big benefit for large teams of developers.
- **Version history.** The system will keep a history of all saved changes to the code. This not only allows you to see what has changed in a file but allows you to go back to a previous version if needed.
- **Generate release notes.** Code can be linked to a release, and as a result, release notes can be generated. This means time is saved in generating it manually and searching for the changes.
- **Backup of code.** A centralized place on a server where the source code is stored ensures there is the main location for the code (other than the developer's machine). It also allows for easy backup of the code, depending on your server setup.

• **The CI/CD Process Continuous integration**

The software development process of routinely integrating code changes into a shared code repository is known as continuous integration (CI). This would typically happen once or multiple times per day (depending on the amount of code commits), and this practise promotes modest changes to be committed more frequently than large changes. Each commit initiates a build, during which tests are run to see if the changes have broken anything.

Continuous delivery (CD) and continuous deployment

Continuous delivery refers to the capacity to send integrated code to production on a regular basis, whether it's bug fixes or new features. It means that if you want to release your "green builds," you can do it with a single click. Continuous deployment takes things a step further by allowing you to deploy every main branch modification that passes the CI live. However, you may have business reasons for not doing so automatically, or you may need to conduct manual testing. Benefits of continuous integration and delivery (CI/CD)

- **Fast feedback loop:** What you don't know can really hurt you in software development. A team's progress can be slowed by a lack of feedback on the consistency and effect of the improvements made. Continuous integration tools can alleviate a lot of this pain by providing simple answers to the question "did I break anything?" after each commit.
- **Increase transparency and visibility:** When the CI/CD pipeline is set up, the team will be able to see what's going on with the builds and have the most up-to-date test results, allowing them to raise concerns and schedule their work in context. It is possible to determine which changes are more likely to cause a build to fail.
- **Avoid integration issues:** Even if a specific piece of software is fine on its own in terms of implemented code, we will still need to make sure it plays nice with everything else. Continuous integration supports connecting the pieces of the software every day.
- **Detect and fix issues early:** The more bugs there are, the more difficult it is to test and locate them. Not all of the testing can be automated, and automating what can take a lot of time. However, doing so contributes to long-term growth and reduces technological debt.
- **Improve quality and testability:** On the inside, a product's testability is determined by how controllable, detectable, bug-free, and decomposable it is. The ease with which new builds can be obtained and the resources available determine the testability outside. Continuous integration and delivery drive both since it is needed to write tests and run them.

3.6.5.1 Technologies Used

- **Git and GitHub**

GitHub, Inc. is an Internet hosting company that specialises on Git-based software development and version control. Git is a version control system that is distributed. A distributed version control system means that each collaborator (any developer working on a team project) has a local repository of the project on his or her local machine, as opposed to a central repository, which requires team members to constantly update their work to the main central repository. Every project also has access control and collaboration tools including bug tracking, feature requests, task management, continuous integration, and wikis. Git repository structure consists of 4 parts:

- **Working directory:** This is your local directory where you make the project (write code) and make changes to it.
- **Staging Area (or index):** this is an area where you first need to put your project before committing. This is used for code review by other team members.
- **Local Repository:** this is your local repository where you commit changes to the project before pushing them to the central repository on Github. This is what is provided by a distributed version control system. This corresponds to the `.git` folder in our directory.
- **Central Repository:** This is the main project on the central server, a copy of which is with every team member as a local repository.

3.6.6 Process Methodologies

- **Agile Methodology**

The project is being completed utilising the Agile methodology, which is a quick and nimble approach to meeting the project's objectives. The project's purpose is to develop software that will help the business evaluate and track software project process adherence. Before the actual project work could begin, there were a few chores that needed to be accomplished. Some of these items include distributing responsibilities among the team, understanding the resources that will be used, studying the procedures that

will be employed in the creation of this project, and so on. Understanding the back-end and front-end code bases, as well as the expectations of clients and stakeholders, was crucial.

Before beginning the projects, make a comprehensive assessment of everything and of all required technology was conducted in order to make efficient use of it. Several modules were used in the project to achieve the objectives described. This chapter is broken down into :

Life-cycle of the Agile methodology:

- Methodology for the Study
- Feasibility Studies
- Hardware and Software Requirements
- Software Requirements Specification
- Overview of Development Phases
- Experimental and Analytical Work Completed in the Project
- Modelling, Analysis and Design
- Implementation
- Prototype and Testing

The project's principal methodology is the agile development strategy. Agile methodology has recently gained popularity due to its improved performance and ease of client delivery. In comparison to other techniques, the Agile model has proven to be effective and satisfactory in terms of meeting customer expectations because clients are actively involved in the development process. The models' performance and outcomes are expected to appeal to the project's stakeholders.

The major goal of the project is to apply the Agile Development approach to fulfil the defined goals. Experimentation and consistency tests were both considered. The efficacy of a methodology to a specific problem statement can only be evaluated and concluded when it achieves its objectives with sufficient precision. This is possible if the software is well-designed to meet the goals.

3.7 Modeling, Analysis and Design

3.7.1 Design

We grasped the general look and working of the project during modelling, analysis, and design, including how the frontend would look, the functionality the project would have, and the flow of utilising the application to execute automated scanning, remediation, and rollback.

The following image shows the design of the project :-

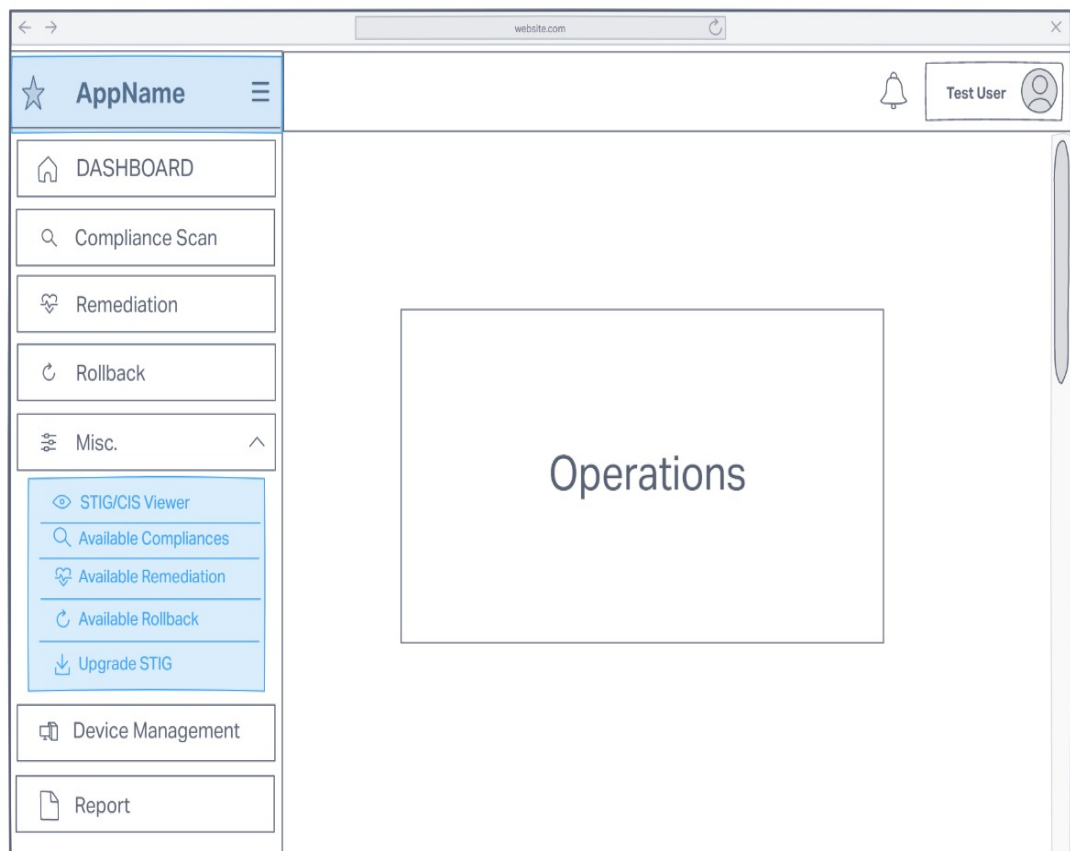


FIGURE 3.3: Snapshot of Dashboard

Here we can see the general structure of the GUI. The following are the main parts of the GUI:-

Dashboard: It is the first window that appears when a user opens the tool. It is useful when the user wants to have an overall view of the processes, running scans, history, available devices, etc.

Compliance Scan: This is the window where the user can run a scan for a particular type of device/system by choosing the relevant options.

Remediation: When a vulnerability is found for a particular profile/system, the remediation section helps in fixing the vulnerability. But this is only possible if the respective automation script is available for the remediation.

Rollback: If a remediation for a particular vulnerability is applied, which later causes some problems, then the rollback section helps to undo the remediation changes with the help of its respective script.

Device Management: This section is desiccated to operations related to the devices and their management. In this window, a user can add, remove and manage the devices on which the scans and scripts can be run. It is possible to automate the process and run the scans on multiple devices.

3.8 Implementation

The backend code was totally developed in python, whereas, the frontend was developed in HTML, CSS and JavaScript. Bootstrap was also implemented in the front-end to fasten the process of frontend development. The frontend was launched with the help of a python GUI Framework called PySide2, which creates a chromium-based window on which the frontend is displayed. The front-end and the backend were developed majorly using Visual Studio IDE.

Code-Snippet These two code snippet shows the implementation of automation script for one compliance rule of SLES-15. This compliance rule is about checking whether the version of SLES-15 is updated one or older version.

```
control 'SLES-15-010000' do
  title 'The SUSE operating system must be a vendor-supported release.'
  desc '
    A SUSE operating system release is considered "supported" if the vendor continues to provide
    security patches for the product. With an unsupported release, it will not be possible to resolve
    security issues discovered in the system software.
  '
  desc 'check', '
    Verify the SUSE operating system is a vendor-supported release.

    Use the following command to verify the SUSE operating system is a vendor-supported release:

    > cat /etc/os-release

    NAME="SLES"
    VERSION="15"

    Or any SUSE Linux Enterprise 15 Service Pack follow up release.

    NAME="SLES"
    VERSION="15-SPx"

    Current End of Life for SLES 15 General Support is 31 Jul 2028 and Long-term Support is until 31 Jul
    2031.

    If the release is not supported by the vendor, this is a finding.
  '
  desc 'fix', '
    Upgrade the SUSE operating system to a version supported by the vendor. If the system is not
    registered with the SUSE Customer Center, register the system against the correct subscription.

    If the system requires Long-Term Service Pack Support (LTSS), obtain the correct LTSS subscription
    for the system.
  '
end
```

FIGURE 3.4: Code snippet of implementation of automation script

```

impact 0.7
tag severity: 'high'
tag gtitle: 'SRG-OS-000480-GPOS-00227'
tag satisfies: ['SRG-OS-000480-GPOS-00227']
tag gid: 'V-234800'
tag rid: 'SV-234800r622137_rule'
tag stig_id: 'SLES-15-010000'
tag cci: ['CCI-001230']

# Write the compliance 'describe' here
describe command('cat /etc/os-release') do
  its('stdout') { should match /NAME="SLES"/ } |
  its('stdout') { should match /VERSION="15"/ }
end

# Write the feedback echo commands inside the '__DATA__' block
# To sent raw string message as feedback, replace 'be_executable' with 'be_message'
dataBlock = <<- __DATA__
cat /etc/os-release
__DATA__
describe feedback(dataBlock) do
  its('content') { should be_executable }
end
end

```

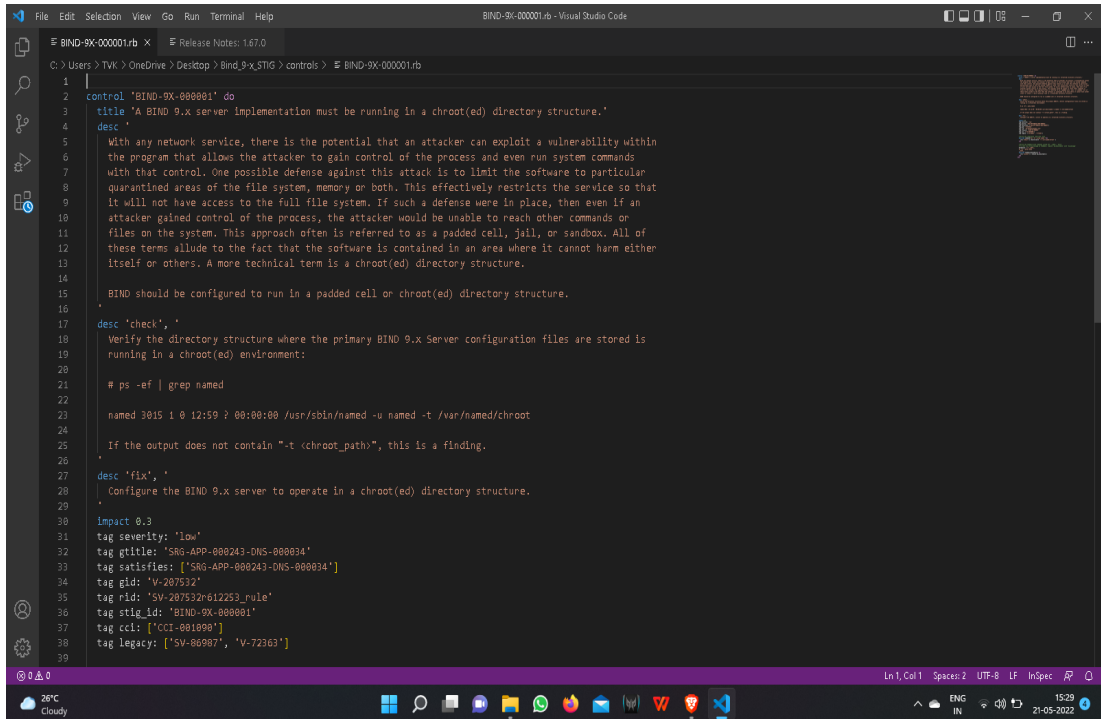
FIGURE 3.5: Code snippet of implementation of automation script

```

30 impact 0.3
31 tag severity: 'low'
32 tag gtitle: 'SRG-APP-000243-ONS-000034'
33 tag satisfies: ['SRG-APP-000243-ONS-000034']
34 tag gid: 'V-207532'
35 tag rid: 'SV-207532r612253_rule'
36 tag stig_id: 'BIND-9X-000001'
37 tag cci: ['CCI-001090']
38 tag legacy: ['SV-86987', 'V-72303']
39
40 # Write the compliance 'describe' here
41 describe command("ps -ef | grep named")do
42   its('stdout'){ should match '-t /var/named/chroot' }
43 end
44
45 # Write the feedback echo commands inside the '__DATA__' block
46 # To sent raw string message as feedback, replace 'be_executable' with 'be_message'
47 dataBlock = <<- __DATA__
48 ps -ef | grep named
49 __DATA__
50 describe feedback(dataBlock) do
51   its('content') { should be_executable }
52 end
53 end
54
55

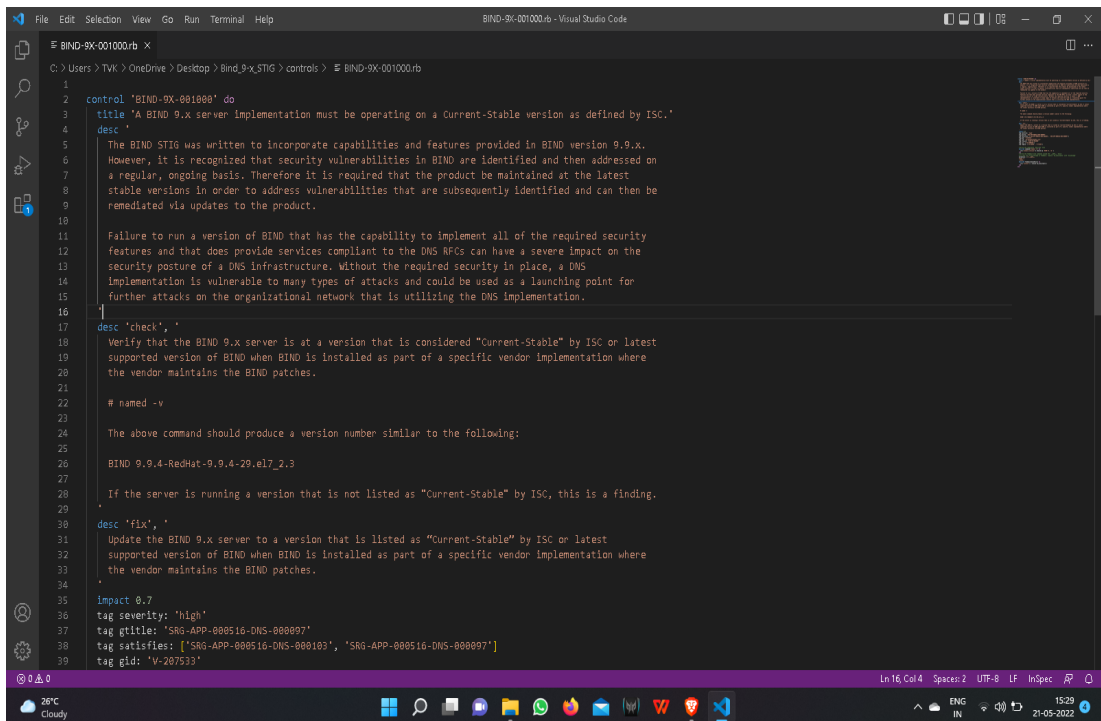
```

FIGURE 3.6: Code snippet of implementation of automation script



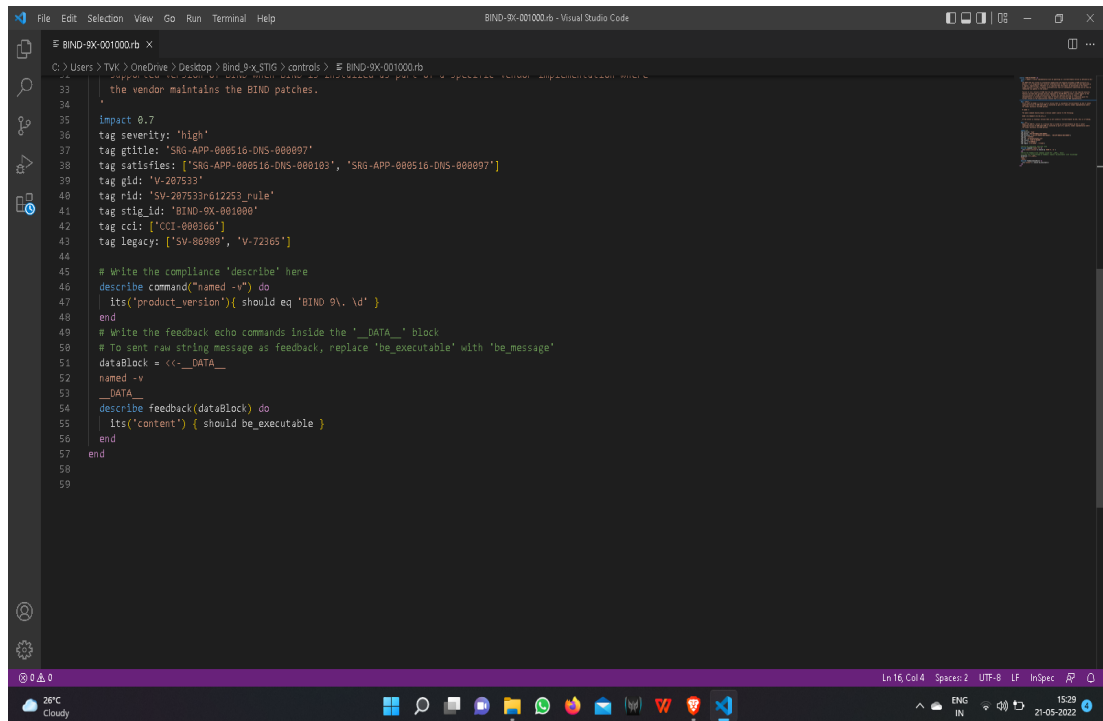
```
1 control 'BIND-9X-000001' do
2   title 'A BIND 9.x server implementation must be running in a chroot(ed) directory structure.'
3   desc '
4     With any network service, there is the potential that an attacker can exploit a vulnerability within
5     the program that allows the attacker to gain control of the process and even run system commands
6     with that control. One possible defense against this attack is to limit the software to particular
7     quarantined areas of the file system, memory or both. This effectively restricts the service so that
8     it will not have access to the full file system. If such a defense were in place, then even if an
9     attacker gained control of the process, the attacker would be unable to reach other commands or
10    files on the system. This approach often is referred to as a padded cell, jail, or sandbox. All of
11    these terms allude to the fact that the software is contained in an area where it cannot harm either
12    itself or others. A more technical term is a chroot(ed) directory structure.
13
14    BIND should be configured to run in a padded cell or chroot(ed) directory structure.
15  '
16  desc 'check', '
17    Verify the directory structure where the primary BIND 9.x Server configuration files are stored is
18    running in a chroot(ed) environment:
19
20    # ps -ef | grep named
21
22    named 3015 1 0 12:59 ? 00:00:00 /usr/sbin/named -u named -t /var/named/chroot
23
24    If the output does not contain "-t <chroot_path>", this is a finding.
25  '
26  desc 'fix', '
27    Configure the BIND 9.x server to operate in a chroot(ed) directory structure.
28  '
29  impact 0.3
30  tag severity: 'low'
31  tag gtitle: 'SRG-APP-000243-DNS-000034'
32  tag satsfiles: ['SRG-APP-000243-DNS-000034']
33  tag gid: 'V-207532'
34  tag rid: 'SV-207532-612253_rule'
35  tag stig_id: 'BIND-9X-000001'
36  tag cci: ['CCI-001090']
37  tag legacy: ['SV-06907', 'V-72303']
38
39
```

FIGURE 3.7: Code snippet of implementation of automation script



```
1 control 'BIND-9X-001000' do
2   title 'A BIND 9.x server implementation must be operating on a Current-Stable version as defined by ISC.'
3   desc '
4     The BIND STIG was written to incorporate capabilities and features provided in BIND version 9.9.x.
5     However, it is recognized that security vulnerabilities in BIND are identified and then addressed on
6     a regular, ongoing basis. Therefore it is required that the product be maintained at the latest
7     stable versions in order to address vulnerabilities that are subsequently identified and can then be
8     remediated via updates to the product.
9
10    Failure to run a version of BIND that has the capability to implement all of the required security
11    features and that does provide services compliant to the DNS RFCs can have a severe impact on the
12    security posture of a DNS infrastructure. Without the required security in place, a DNS
13    implementation is vulnerable to many types of attacks and could be used as a launching point for
14    further attacks on the organizational network that is utilizing the DNS implementation.
15  '
16  desc 'check', '
17    Verify that the BIND 9.x server is at a version that is considered "Current-Stable" by ISC or latest
18    supported version of BIND when BIND is installed as part of a specific vendor implementation where
19    the vendor maintains the BIND patches.
20
21    # named -v
22
23    The above command should produce a version number similar to the following:
24
25    BIND 9.9.4-Redhat-9.9.4-29.el7_2.3
26
27    If the server is running a version that is not listed as "Current-Stable" by ISC, this is a finding.
28  '
29  desc 'fix', '
30    Update the BIND 9.x server to a version that is listed as "Current-Stable" by ISC or latest
31    supported version of BIND when BIND is installed as part of a specific vendor implementation where
32    the vendor maintains the BIND patches.
33  '
34  impact 0.7
35  tag severity: 'high'
36  tag gtitle: 'SRG-APP-000516-DNS-000097'
37  tag satsfiles: ['SRG-APP-000516-DNS-000103', 'SRG-APP-000516-DNS-000097']
38  tag gid: 'V-207533'
39
```

FIGURE 3.8: Code snippet of implementation of automation script



```
File Edit Selection View Go Run Terminal Help BIND-9X-001000.rb - Visual Studio Code
C:\Users> Tvk > OneDrive > Desktop > Bind_9x_STIG > controls > BIND-9X-001000.rb
33 the vendor maintains the BIND patches.
34
35 impact 0.7
36 tag severity: 'high'
37 tag gtitle: 'SRG-APP-000516-DNS-000097'
38 tag satisfies: ['SRG-APP-000516-DNS-000103', 'SRG-APP-000516-DNS-000097']
39 tag gid: 'V-207533'
40 tag rid: 'SV-207533r612253_rule'
41 tag stig_id: 'BIND-9X-001000'
42 tag cci: ['CCI-000366']
43 tag legacy: ['SV-80909', 'V-72365']
44
45 # Write the compliance 'describe' here
46 describe command("named -v") do
47   its('product_version'){ should eq 'BIND 9\.\.\.' }
48 end
49 # Write the feedback echo commands inside the '._DATA_' block
50 # To sent raw string message as feedback, replace 'be_executable' with 'be_message'
51 dataBlock = <<_DATA_
52   _DATA_
53   _DATA_
54   describe feedback(dataBlock) do
55     its('content') { should be_executable }
56   end
57 end
58
59
```

FIGURE 3.9: Code snippet of implementation of automation script

3.8.1 Project Structure

The project consists of the front-end and the backend. The front-end is developed with the help of HTML, CSS and Javascript. JQuery was used to make the use of javascript easier and more effective. Bootstrap was useful in increasing the development of the front-end. A python GUI framework called PySide2 was also used in the GUI development, which helps us launch the GUI, and helped python directly communicate with the backend and frontend code without any other requirement in between. The main aim of the program is to automate the compliance scan, and in order to do so, there are certain functionalities for performing the actions: -

- Dashboard
- Compliance Scan
- Remediation
- Rollback
- Device Management

These functionalities are discussed in detail in the ‘design’ section and the ‘analysis and results’ section of the report.

3.8.2 User Interface

The project follows a dashboard-based User Interface. It is developed with the help of HTML, CSS and JavaScript. Bootstrap was used to fasten the process of frontend development. The theme colors for the are white and grey and blue for the buttons.

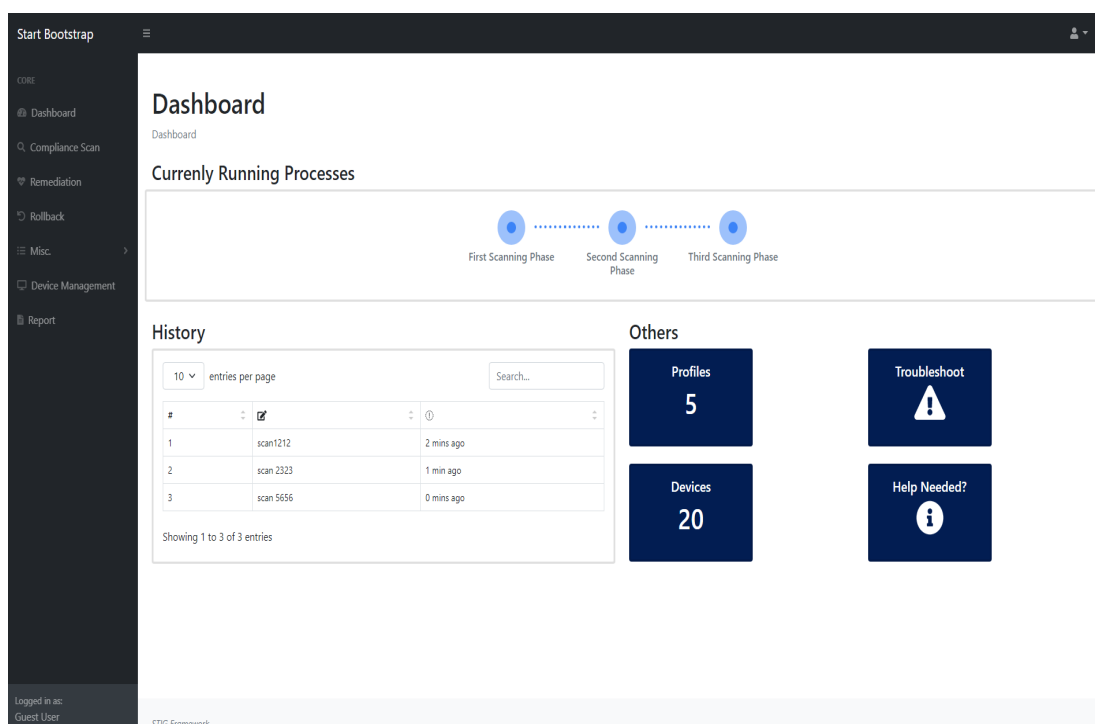


FIGURE 3.10: Dashboard

As you can see in the dashboard window in the above-mentioned diagram, the dashboard shows a rough view of the devices, history and the currently running processes. The other windows will be covered in the ‘results and analysis’ section.

3.9 Unit Testing

The unit testing was performed for the frontend development where the inputs, buttons, sections and other parts of the GUI were tested. Some of the test results are shared below: -

TABLE 3.4: Unit Tests for the GUI

Feature Tested	Input	Expected Output	Result
Navbar Buttons	Clicked on a button to open the respective window.	Respective window opened.	Success
Radio button	Button is chosen on clicking on the radio button.	The radio button works.	Success
Dropdown box	Expected data is present when a dropdown box is clicked	Current data is displayed	Success
Hide button for certain sections.	On pressing a certain button “selected scan”, a hidden section is displayed	Division is displayed and it accepts the values entered by the user.	Success
Adding a new device	In the device management section, the new device is successfully added.	New deceive is displayed in the table on filling up the form to add a new device.	Success

Chapter 4

RESULTS, DISCUSSIONS AND CONCLUSIONS

4.1 Results & Analysis

In our security compliance automation system, we employed STIG and CIS standards to check for compliance. During the automated process, the framework allows users to control devices for which scanning is desired. It also allows the user to choose a compliance rule, and if that rule isn't met, it can either automatically rectify it or the user can choose a specific rule to be remedied. If an issue arises during the repair process, it will perform a rollback to restore the previous state..

Dashboard: It is the first window that appears when a user opens the tool. It is useful when the user wants to have an overall view of the processes, running scans, history, available devices, etc.

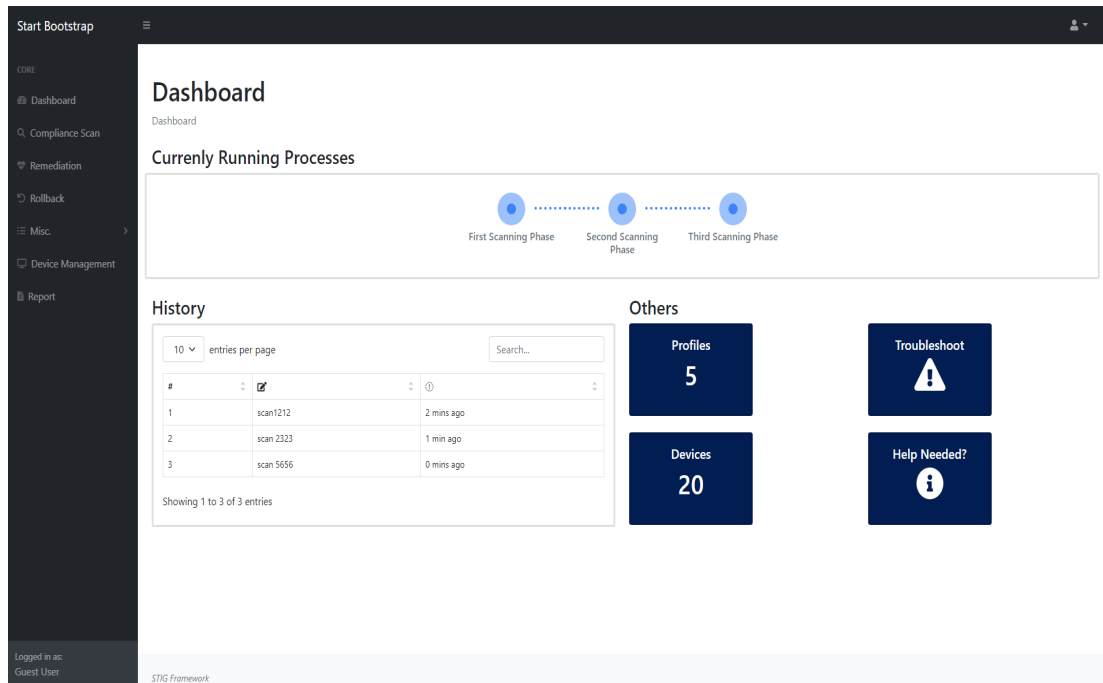


FIGURE 4.1: Dashboard of framework

Compliance Scan: This is the window where the user can run a scan for a particular type of device/system by choosing the relevant options.

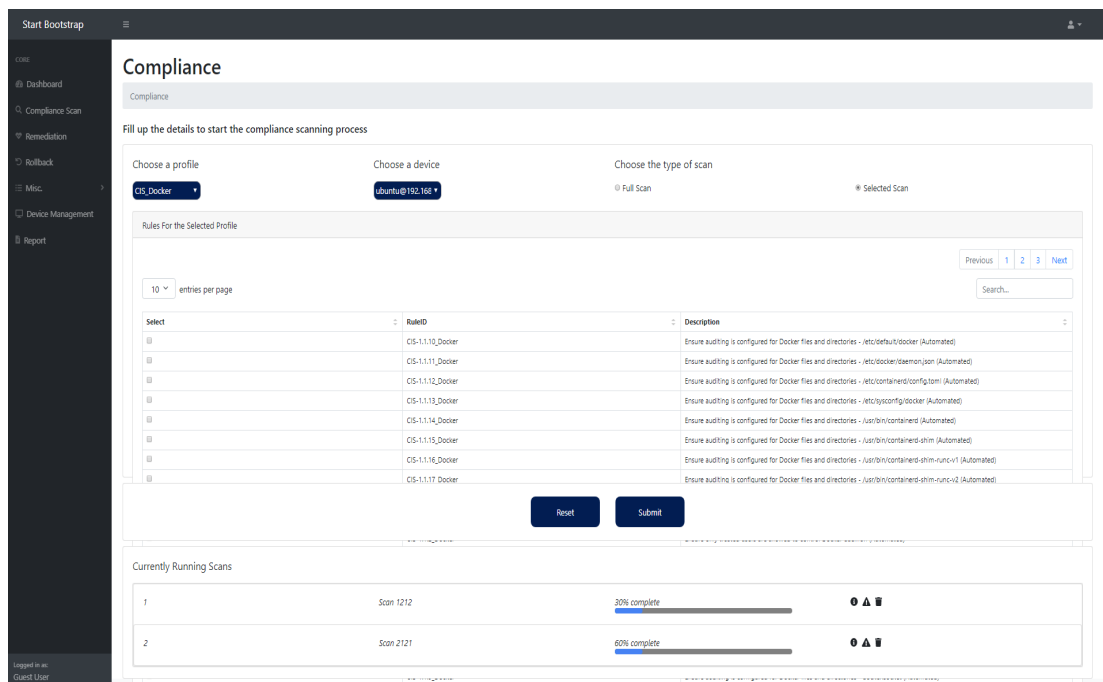


FIGURE 4.2: Compliances available in framework

Remediation: When a vulnerability is found for a particular profile/system, the remediation section helps in fixing the vulnerability. But this is only possible if the respective automation script is available for the remediation.

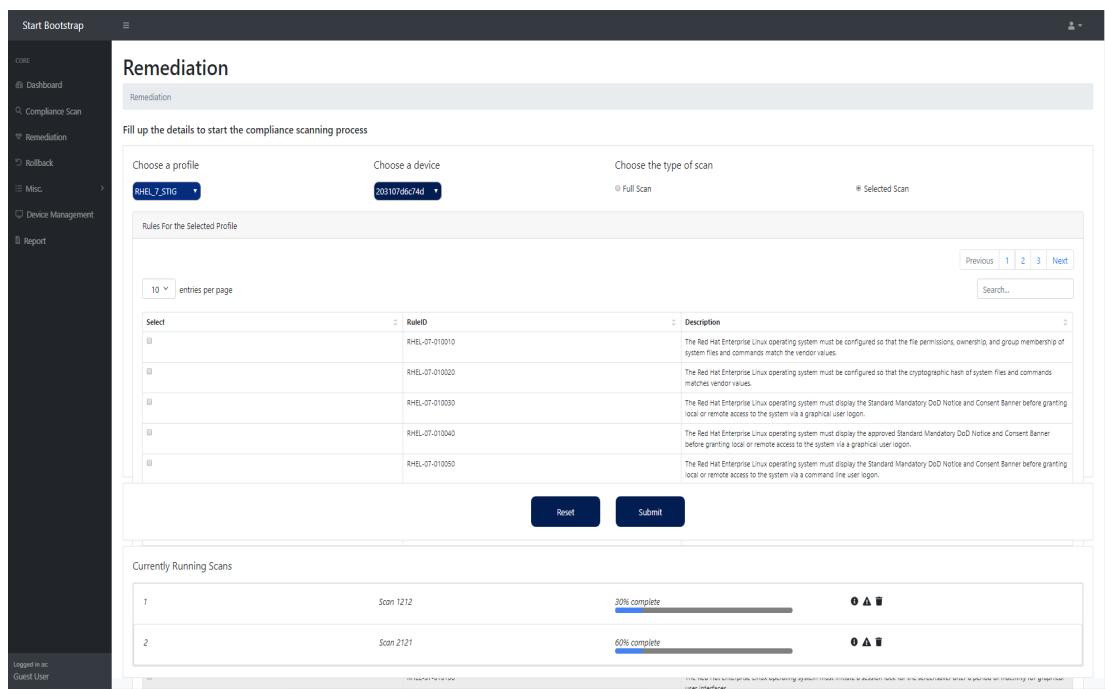


FIGURE 4.3: Remediation available in framework

Rollback: If a remediation for a particular vulnerability is applied, which later causes some problems, then the rollback section helps to undo the remediation changes with the help of its respective script.

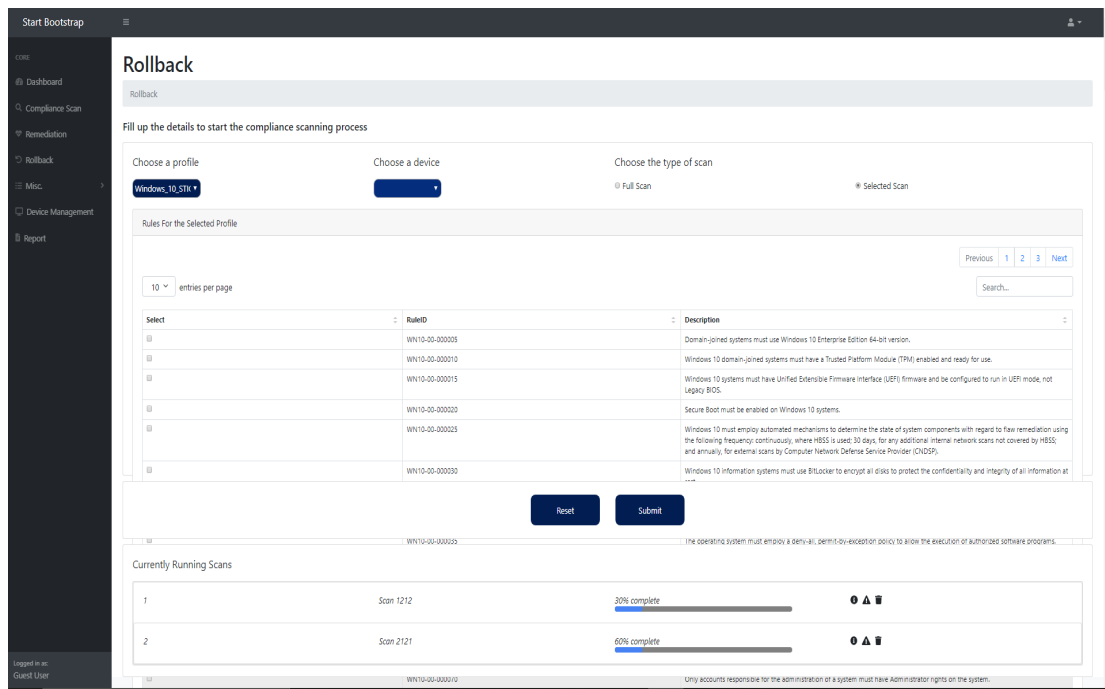


FIGURE 4.4: Rollback available in framework

Device Management: This section is desiccated to operations related to the devices and their management. In this window, a user can add, remove and manage the devices on which the scans and scripts can be run. It is possible to automate the process and run the scans on multiple devices.

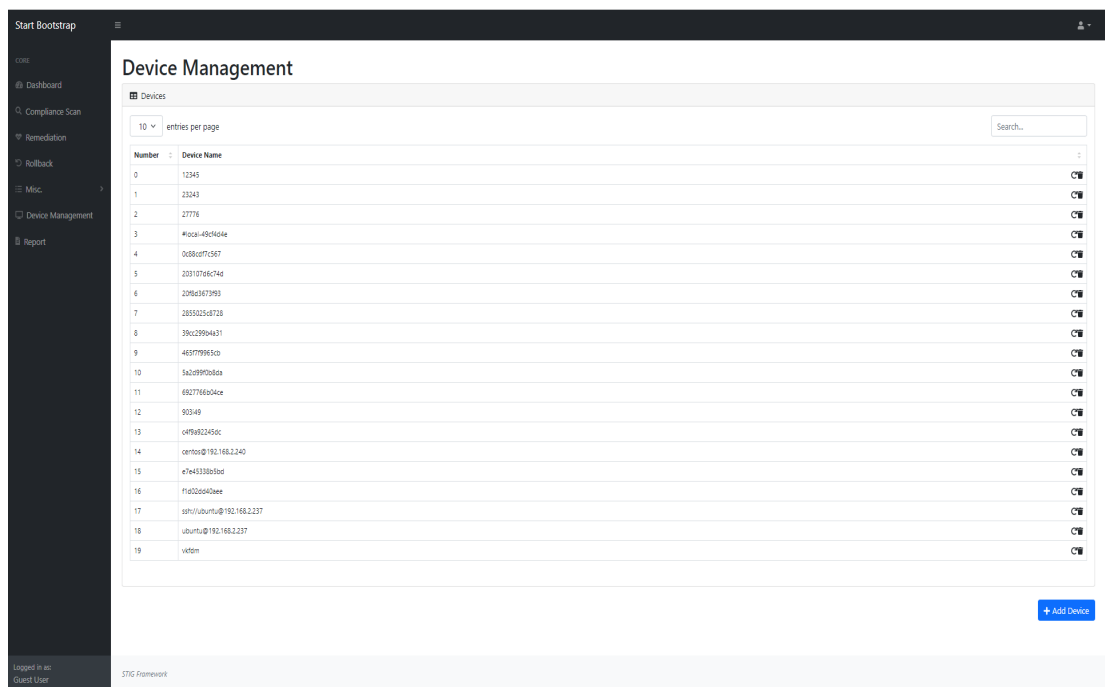


FIGURE 4.5: Device Management

4.2 Comparative Study

Security, particularly security compliance, is a major worry that is delaying broad adoption of cloud computing and third-party solutions in the organisation. Businesses require certain levels of security compliance for a variety of reasons, including business requirements, government rules, and trust.

Until now, security compliance or auditing data has been manually generated by security specialists. This procedure entails manual data gathering and assessment, which is time-consuming and expensive. As a result, an automated compliance tool is required to verify and communicate the level of compliance of various systems, devices, and servers. By automatically confirming compliance, such a solution can reduce human intervention and, as a result, cost and time. The technology will also allow security providers to communicate information about security compliance using a single architecture. As a result of the shared architecture, clients can compare different security providers based on their security requirements.

With these objectives in mind, we created an architecture to provide an automated security compliance tool for a variety of platforms, including Windows, Linux, and servers. We've also outlined four different ways to accomplish this automation. These four possible ways include API, vulnerability scanning, log analysis, and manual entry, which are four design patterns for collecting data from a cloud system. Finally, we used the proposed architecture to create a proof-of-concept prototype of this automated security compliance solution.

4.3 Discussions

The purpose of this project is to investigate the potential of developing an automated security compliance solution for various systems, servers, and other devices. This section goes over the most important aspects of reaching this goal. As there was no such technology when we started the project to automate compliance checks and remediate those who did not meet compliance standards. As a result, we had to start over. First, we had to figure out how the system would work and what the key components would be. We designed a high-level architecture for the tool based on our initial understanding of it. We then created a system-level architecture for many platforms, which we can use to build an automated security compliance tool.

During the implementation, we encountered a number of difficulties. The first challenge was deciding which standard to check for compliance with. Although most of the controls stated in one standard are likewise defined in other standards, sometimes somewhat differently, most of them do not include any implementation guidance. After reviewing numerous standards, we opted to develop our proof-of-concept prototype using the STIG (Security Technical Implementation Guide) and the CIS (Center for Internet Security). The advantage of STIG and CIS (Center for Internet Security) over other standards is that they provide implementation guidance for the controls established in them. These standards are also the most extensively researched and applied by businesses.

4.4 Conclusions

Compliance scanning is unique from vulnerability scanning in that it yields specific and important results. Compliance with STIG and CIS (Center for Internet Security) is mission vital for every organisation in today's climate because of the valuable information you are ultimately entrusted with protecting and the risks associated with non-compliance. As a result, in addition to vulnerability scans, compliance scanning should be considered as an additional tool for business executives to build holistic security postures. Security, particularly security compliance, remains a hurdle to large-scale cloud adoption in the industry, despite technological developments. And it is here that an automated security compliance solution can assist the cloud vendor and the user in establishing confidence. This technology can also help the cloud vendor save money and time by automating the compliance evaluation approach. Since a result, this project is both theoretical and practical in nature, as it examines several design approaches for creating such a tool and constructs a prototype that demonstrates how it can be done.

4.5 Scope for Future Work

The research conducted as part of the project effort gives up new avenues to investigate. The first goal would be to implement the additional compliance standards to make the tool more flexible, as we have developed the fmarework in CLI and graphical user interface(GUI) for STIG(Security Technical Implementation Guide) and CIS(Center for Internet Security) compliances.

The technique's second purpose is to be evaluated in terms of performance indicators such required time, CPU, and memory. Time will be one of the most important performance parameters for such an on-demand information generating system. We can use a variety of methods to construct a single security rule and measure performance metrics. This will aid us in determining the most effective approach for gathering data from the cloud. Throughout the project, we looked at ways to automatically monitor the compliance status of the cloud platform, various operating systems, and virtual machines running on the platform. A new field of research will be verifying the security compliance of virtual machine instances running on the cloud with relevant standards.

Bibliography

- [1] K. W. Ullah, “NTNU open: *Automated security compliance tool for the cloud*”, Automated Security Compliance tool for the cloud, 2012. [Online]. Available: <https://ntnuopen.ntnu.no/ntnu-xmlui/handle/11250/262711>. [Accessed: 01-May-2022].
- [2] N. Lylina, A. Atteya, P. Raiola, M. Sauer, B. Becker, and H.-J. Wunderlich, “*Security Compliance Analysis of reconfigurable Scan Networks*”, 2019 IEEE International Test Conference (ITC), 2019.
- [3] “*Security Technologies for manufacturing and Control Systems*”. Research Triangle Park, NC: ISA, 2004.
- [4] G. Francia, B. Estes, R. Francia, V. Nguyen, and A. Scroggins, “*The design and implementation of an Automated Security Compliance Toolkit: A pedagogical exercise*”, Journal of Digital Forensics, Security and Law, 2007.
- [5] Center for Internet Security (2006), “Next Generation Scoring Tool”, <http://www.cisecurity.org>. Access date: October 01, 2006.
- [6] “*Accuplacer next generation scoring placement chart*”. [Online]. Available: <https://www.crowder.edu/wp-content/uploads/2022/04/Accuplacer-Placement-Chart-March-2022.pdf>. [Accessed: 01-May-2022].
- [7] K. Julisch, “*Security compliance*”, Proceedings of the 2008 workshop on New security paradigms - NSPW '08, 2008.
- [8] M. Siponen, S. Pahnla, and M. A. Mahmood, “*Compliance with information security policies: An empirical investigation*”, Computer, vol. 43, no. 2, pp. 64–71, 2010.
- [9] “*Computer Security Board appointed by NIST*”, Computer Fraud and Security Bulletin, vol. 11, no. 5, p. 2, 1989.

- [10] “*CMMCSCORECARD: Cybersecurity Education: Cloud Security Management*”, eFortresses. [Online]. Available: <https://efortresses.com/>. [Accessed: 17-May-2022].
- [11] “*Security Guidance for Critical Areas of Focus in Cloud Computing*”, V1.0. [Online]. Available: <https://downloads.cloudsecurityalliance.org/assets/research/security-guidance/csaguide.v3.0.pdf>. [Accessed: 01-May-2022].
- [12] Schwartz, E. (2006), “*The Compliance Headache*”, InfoWorld, 12. .
- [13] “*Standards for security categorization of Federal Information and Information Systems*”. Gaithersburg, MD: Computer Security Division, Information Technology Laboratory, National Institute of Standards and Technology, 2004.
- [14] “*Maintaining perspective: Enterprise and compliance risk management*”, Corruption, Crime amp; Compliance, 10-Dec-2020. [Online]. Available: <https://blog.volkovlaw.com/2020/12/maintaining-perspective-enterprise-and-compliance-risk-management/>. [Accessed: 01-May-2022].

Appendix A

Appendix A Company

A.1 TATA ELXSI LIMITED

A.1.1 About Company

Tata Elxsi commenced its business on 5th May 1989 in Bangalore, the Silicon Valley of India, to develop and promote applications of electronics, embedded systems, and software. The Mission was to foster innovation in the fast-emerging IT market and accelerate the adoption of leading-edge technologies. Today, Tata Elxsi is recognized as a premium engineering service provider worldwide and amongst the leaders in the automotive, media, broadcast, communications, and healthcare industries.

Tata Elxsi brings together the best technology and user-centric design expertise to help customers deliver innovative solutions and great consumer experiences. Our integrated Design and Technology teams help enterprises reimagine their products and services – from strategy, consumer research and insights, to service and experience design, technology implementation, integration, launch, and beyond.

At Tata Elxsi we work closely with customers - right from advanced R and D in new technology and system architecture exploration to actual development, validation, and deployment. This includes emerging technologies such as IoT (Internet of Things), cloud, smart mobility, and artificial intelligence. Thereby creating new opportunities for businesses to improve operational efficiency, reduce costs and deliver new services to their consumers.

This is supported by world-class product development processes and methodologies that have been evolved and matured over the last 30 years along with a global ecosystem of partners, design studios, that support access to the latest technology, tools and help drive faster time-to-market for our customers.

A.1.2 Services

- Research and Strategy
- Design
- - Portfolio
- Test and Validation
- Operate and Automate
- Industry 4.0
- Product Engineering